



PGP • TREINAMENTO



EDIÇÃO DE 13 DE JUNHO DE 2026

Pacote de *Modelos*

Programa de Governança em Privacidade

21 templates editáveis para a implementação da LGPD em Instituições Públicas brasileiras.

6

Documentos Formais

6

Documentos
Institucionais

9

Fichas Operacionais

Como usar este Pacote

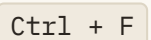
Este documento reúne **21 modelos editáveis** para a implementação da LGPD em órgãos públicos. Diferente da Cartilha (que é guia descritivo), aqui você tem *templates prontos para editar* — abra no Word, navegue pelo sumário, vá direto ao modelo que precisa e adapte.

1 Como os modelos estão organizados

-  Cada modelo começa em **página nova** com cabeçalho 'Modelo NN — Nome' para fácil localização.
-  Caixa **azul** logo abaixo do título: instrução breve de *quando* usar o modelo.
-  Corpo do template com campos a preencher destacados em **[NOME DA INSTITUIÇÃO]**.
-  Caixa **amarela** ao final: exemplo preenchido com dados fictícios para você ver como fica.

2 Convenção de placeholders

Os campos a preencher seguem padrão de fácil identificação no Word — use

 **Ctrl + F** para encontrar todos:

[NOME DA INSTITUIÇÃO]	— nome completo	[CIDADE]	— cidade-sede
[CNPJ]	— CNPJ da Instituição	[NOME DO ENCARREGADO]	— DPO designado
[E-MAIL] / [TELEFONE]	— contatos	[DATA]	— data de emissão
[NOME DO PROCESSO] , [NOME DO OPERADOR] , [NOME DO TITULAR] — contextuais			

3 Recomendação de uso

Não preencher tudo de uma vez. O PGP é processo gradual — preencha os modelos na ordem das fases (Preliminar primeiro: Ato de Designação · Carta Alta Gestão · Termômetro) e vá avançando conforme o Plano de Ação da Instituição.

 *Sugestão:* salvar uma cópia **antes** de editar (Salvar como...) — o original fica intacto para futura consulta ou para distribuir a outros servidores/setores.

Sumário dos Modelos

Os 21 modelos estão organizados em 3 grupos.



GRUPO 1 · 6 MODELOS

Documentos Formais

- 01  Ato de Designação do Encarregado
- 02  Portaria de Instituição do Comitê Gestor (companheiro do Modelo 01, Fase 1)
- 03  Carta para a Alta Gestão
- 04  Roadmap de 90 dias
- 05  Aviso de Privacidade público
- 06  Plano de Resposta a Incidentes (PRI)



GRUPO 2 · 6 MODELOS

Documentos Institucionais

- 07  Política do PGP (documento mater)
- 08  Cláusulas LGPD para contratos
- 09  Política de Retenção e Descarte
- 10  Termo de Consentimento do Titular
- 11  Comunicação de Incidente à ANPD
- 12  Comunicação de Incidente aos Titulares



GRUPO 3 · 9 MODELOS

Fichas Operacionais

- 13  Termômetro: você + sua Instituição
- 14  Matriz de Priorização (Res. ANPD nº 2/2022)

- 15  Ficha de Processo (Inventário)
- 16  Ficha de Risco com matriz P × I
- 17  GAP — Planilha de Avaliação de Controles
- 18  Plano de Ação
- 19  RIPD — Relatório de Impacto (8 seções)
- 20  Ficha de Operador (Terceiro)
- 21  Registro de Solicitação DSR



MODELO 01 • GRUPO 1 • DOCUMENTOS FORMAIS

Ato de Designação do Encarregado

QUANDO USAR

No início da Fase 1 do PGP, pra cumprir o Art. 41 da LGPD. É documento formal que designa o Encarregado pelo Tratamento de Dados Pessoais (DPO). Deve ser publicado no diário oficial ou veículo institucional equivalente.

Template

ATO DE DESIGNAÇÃO Nº **[NÚMERO/AAAA]**

(Designação do Encarregado pelo Tratamento de Dados Pessoais)

Designa o(a) Encarregado(a) pelo Tratamento de Dados Pessoais (DPO) de **[NOME DA INSTITUIÇÃO]**, em cumprimento ao art. 41 da Lei nº 13.709/2018 — Lei Geral de Proteção de Dados Pessoais (LGPD).

[A AUTORIDADE MÁXIMA — ex: O(A) PREFEITO(A) MUNICIPAL DE CIDADE], no uso de suas atribuições legais e regimentais,

CONSIDERANDO que a Lei nº 13.709, de 14 de agosto de 2018 (LGPD), em seu art. 41, determina ao controlador a indicação de Encarregado pelo Tratamento de Dados Pessoais;

CONSIDERANDO o disposto na Resolução CD/ANPD nº 18, de 16 de julho de 2024, que regulamenta a atuação do Encarregado;

CONSIDERANDO a necessidade de estabelecer canal formal de comunicação com a Autoridade Nacional de Proteção de Dados — ANPD e com os titulares de dados pessoais tratados no âmbito de **[NOME DA INSTITUIÇÃO]**;

RESOLVE:

Art. 1º Designar **[NOME DO ENCARREGADO]** como Encarregado(a) pelo Tratamento de Dados Pessoais de **[NOME DA INSTITUIÇÃO]**, nos termos do art. 41 da Lei nº 13.709/2018.

Parágrafo único. O canal de comunicação com o(a) Encarregado(a), para efeito do art. 41 §2º da LGPD, fica estabelecido pelos seguintes meios: e-mail **[E-MAIL]**, telefone **[TELEFONE]**, atendimento presencial em **[ENDEREÇO]**.

Art. 2º A escolha do(a) Encarregado(a) considerou os seguintes fundamentos:
[JUSTIFICATIVA DA ESCOLHA – perfil técnico-jurídico, autonomia, acesso à alta administração].

Art. 3º Compete ao(à) Encarregado(a) designado(a), conforme art. 41 §2º da LGPD:

- I – aceitar reclamações e comunicações dos titulares, prestar esclarecimentos e adotar providências;
- II – receber comunicações da Autoridade Nacional de Proteção de Dados – ANPD;
- III – orientar funcionários e contratados quanto às práticas a serem tomadas em relação à proteção de dados pessoais;
- IV – executar as demais atribuições determinadas pelo controlador ou estabelecidas em normas complementares.

Art. 4º Este ato entra em vigor na data de sua publicação, revogadas as disposições em contrário.

[CIDADE], [DATA POR EXTENSO].

[NOME DA AUTORIDADE]
(Autoridade máxima do órgão)

CIENTE E DE ACORDO:

[NOME DO ENCARREGADO]

Encarregado(a) pelo Tratamento de Dados Pessoais



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

ATO DE DESIGNAÇÃO Nº 03/2026

Designa Maria Silva Santos como Encarregada pelo Tratamento de Dados Pessoais da Prefeitura Municipal de Vegas, em cumprimento ao art. 41 da Lei nº 13.709/2018 — LGPD.

Justificativa: Servidora efetiva de carreira jurídica, com pós-graduação em Direito Digital, autonomia funcional e acesso direto ao gabinete.

Contatos: [\[email protected\]](#) · (00) 0000-0000 · Av. Principal, 100 — Centro.



Portaria de Instituição do Comitê Gestor de Privacidade

QUANDO USAR

Na Fase 1 do PGP, junto com o Ato de Designação (Modelo 01). Enquanto o Ato nomeia a PESSOA (o Encarregado), esta Portaria institui a EQUIPE de governança — o Comitê Gestor de Privacidade, instância multidisciplinar que dá sustentação coletiva ao programa (art. 50 da LGPD). Publique no diário oficial ou veículo institucional equivalente.

Template

PORTARIA Nº **[NÚMERO/AAAA]**

(Institui o Comitê Gestor de Privacidade e Proteção de Dados Pessoais)

Institui o Comitê Gestor de Privacidade e Proteção de Dados Pessoais de **[NOME DA INSTITUIÇÃO]** e define sua composição e competências, em consonância com a Lei nº 13.709/2018 (LGPD).

[A AUTORIDADE MÁXIMA – ex: O(A) PREFEITO(A) MUNICIPAL DE CIDADE], no uso de suas atribuições legais e regimentais,

CONSIDERANDO o art. 50 da Lei nº 13.709/2018 (LGPD), que dispõe sobre a adoção de Programa de Governança em Privacidade pelos agentes de tratamento;

CONSIDERANDO que a proteção de dados pessoais é tema transversal, exigindo atuação coordenada das áreas que tratam dados no órgão;

CONSIDERANDO o art. 41 da LGPD e a necessidade de apoio institucional ao Encarregado pelo Tratamento de Dados Pessoais;

RESOLVE:

Art. 1º Fica instituído o Comitê Gestor de Privacidade e Proteção de Dados Pessoais de **[NOME DA INSTITUIÇÃO]**, com a finalidade de coordenar a implementação da LGPD e do Programa de Governança em Privacidade.

Art. 2º O Comitê é composto pelos seguintes membros, representando as áreas que tratam dados pessoais no órgão:

- I — **[NOME]**, Encarregado(a) pelo Tratamento de Dados Pessoais — Coordenador(a) do Comitê;
- II — **[NOME]**, representante da Tecnologia da Informação (TI);
- III — **[NOME]**, representante da área Jurídica / Procuradoria;
- IV — **[NOME]**, representante da Gestão de Pessoas (RH);
- V — **[NOME]**, representante da Comunicação;
- VI — **[NOME]**, representante das áreas donas dos processos críticos (ex: Saúde, Tributário, Assistência Social).

Art. 3º Compete ao Comitê Gestor de Privacidade:

- I — coordenar a implementação e a revisão do Programa de Governança em Privacidade do órgão, nos termos do art. 50 da Lei nº 13.709/2018 (LGPD);
- II — propor, revisar e submeter à autoridade competente a Política de Proteção de Dados Pessoais e as normas internas correlatas;
- III — apoiar o(a) Encarregado(a) no atendimento às requisições dos titulares e às comunicações da Autoridade Nacional de Proteção de Dados — ANPD;
- IV — supervisionar o inventário dos tratamentos de dados pessoais (registro das operações) e a avaliação de riscos e de impacto (RIPD);
- V — promover a capacitação dos agentes públicos e a cultura de proteção de dados no âmbito do órgão;
- VI — deliberar sobre incidentes de segurança envolvendo dados pessoais e acompanhar as medidas corretivas e o plano de resposta.

Art. 4º O Comitê reunir-se-á **[PERIODICIDADE – ex: trimestralmente]** e, extraordinariamente, sempre que convocado por seu Coordenador.

Art. 5º Esta portaria entra em vigor na data de sua publicação.

[CIDADE], [DATA POR EXTENSO].

[NOME DA AUTORIDADE]
(Autoridade máxima do órgão)



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

PORTARIA Nº 12/2026

Institui o Comitê Gestor de Privacidade e Proteção de Dados Pessoais da Prefeitura Municipal de Vegas.

Composição: Maria Silva (Encarregada, Coordenadora) · João Lima (TI) · Ana Costa (Procuradoria) · Pedro Réis (RH) · Lúcia Dias (Comunicação) · Carla Souza (Saúde — processo crítico).

Reuniões trimestrais, com pauta conduzida pela Coordenadora.



MODELO 03 • GRUPO 1 • DOCUMENTOS FORMAIS

Carta para a Alta Gestão

QUANDO USAR

Na Fase Preliminar do PGP. É documento institucional curto apresentado ao dirigente máximo no início do trabalho de adequação. Objetivo: obter patrocínio formal pra o programa.

Template

À *[DESTINATÁRIO – ex: Excelentíssimo(a) Senhor(a) Prefeito(a) Municipal de Vegas]*

Assunto: Patrocínio Institucional ao Programa de Governança em Privacidade (PGP)

01 Justificativa legal

A Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018 – LGPD) está em vigor desde setembro de 2020 e é plenamente aplicável aos órgãos da Administração Pública (Art. 1º e Capítulo IV). *[NOME DA INSTITUIÇÃO]* trata, no exercício de suas atribuições legais, volume expressivo de dados pessoais de cidadãos, servidores e fornecedores — incluindo dados sensíveis. A adequação à LGPD tornou-se obrigação institucional, com responsabilização direta do(a) gestor(a) máximo(a) em caso de descumprimento.

02 Riscos de não-cumprimento

O não-cumprimento expõe o órgão e seus dirigentes a riscos institucionais relevantes:

- ▶ Sanções administrativas pela ANPD: advertências, publicização da infração, repercussão na imagem institucional.
- ▶ Responsabilização civil em caso de incidente (Art. 42 LGPD), com possibilidade de indenizações por dano moral coletivo e individual.

- ▶ Repercussão midiática e perda de confiança da população.
- ▶ Apontamentos em auditorias do Tribunal de Contas e Ministério Público.

03 Pedido

Em razão do exposto, solicitamos formalmente o apoio institucional de Vossa Excelência para a implementação do PGP de **[NOME DA INSTITUIÇÃO]**, especificamente:

- ▶ Designação formal do(a) Encarregado(a) pelo Tratamento de Dados Pessoais (DPO) por ato oficial (art. 41 LGPD);
- ▶ Constituição do Comitê de Governança de Dados Pessoais, com representação multidisciplinar;
- ▶ Alocação de recursos humanos e orçamentários compatíveis com a complexidade dos tratamentos;
- ▶ Inclusão da adequação à LGPD como pauta recorrente das reuniões de gestão.

Comprometemo-nos a apresentar, no prazo de 30 (trinta) dias após o início formal dos trabalhos, o cronograma detalhado de implementação do PGP e a lista priorizada de processos a serem mapeados.

Respeitosamente,

**[NOME DO ENCARREGADO OU RESPONSÁVEL PELA
CONDUÇÃO]**

Encarregado(a) pelo Tratamento de Dados Pessoais

EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

À Excelentíssima Senhora Prefeita Municipal de Vegas

Assunto: Patrocínio Institucional ao Programa de Governança em Privacidade

A Prefeitura Municipal de Vegas trata diariamente dados de 50 mil cidadãos atendidos pela UBS, 320 estagiários por seleção, dados sensíveis de servidores. O PGP estrutura este tratamento conforme a LGPD.

Solicitamos: designação formal do Encarregado · constituição do Comitê (TI/Jurídico/Comunicação/RH/áreas) · rubrica orçamentária na LOA/2027 (~R\$ 40 mil/ano) · agenda mensal do Comitê.



MODELO 04 • GRUPO 1 • DOCUMENTOS FORMAIS

Roadmap de 90 dias

QUANDO USAR

Ao iniciar o PGP, pra dar visibilidade da execução à Alta Gestão. Cronograma de 13 semanas (~3 meses) distribuindo as 7 Fases do PGP em marcos verificáveis. Anexar à Carta da Alta Gestão (Modelo 03).

Template — tabela editável

Estrutura recomendada de 13 marcos. Preencha a coluna 'Responsável' e ajuste prazos à realidade da Instituição:

SEM.	FASE	ATIVIDADE-CHAVE	RESPONSÁVEL
1	Preliminar	Apresentar Carta à Alta Gestão · obter patrocínio formal	[a definir]
2	Fase 1	Designar Encarregado(a) por ato formal · publicar no diário oficial	[a definir]
3	Fase 1	Constituir Comitê de Privacidade · 1ª reunião	[a definir]
4	Fase 2	Levantar setores que tratam dados · selecionar processos prioritários	[a definir]
5	Fase 2	Aplicar Matriz de Priorização Res. CD/ANPD nº 2/2022	[a definir]
6	Fase 3	Iniciar Inventário dos 5 processos prioritários	[a definir]
7	Fase 3	Concluir Inventário · iniciar Análise de Riscos	[a definir]
8	Fase 4	Aplicar GAP Analysis (10-30	[a definir]

		controles)	
9	Fase 5	Consolidar Plano de Ação · aprovar no Comitê	[a definir]
10	Fase 6	Elaborar RIPD dos processos de alto risco	[a definir]
11	Fase 6	Publicar Aviso de Privacidade · estabelecer canal DSR	[a definir]
12	Fase 6	Cadastrar Operadores · iniciar aditamento de contratos	[a definir]
13	Fase 7	Estruturar PRI · apresentar PGP completo à Alta Gestão	[a definir]

EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Sem. 1 · Preliminar · Apresentar Carta à Alta Gestão · Responsável: João Lima (Coord. Jurídico)

Sem. 4 · Fase 2 · Levantar setores · Responsável: Maria Silva (Encarregada)

Sem. 7 · Fase 3 · Concluir Inventário · Responsável: Maria Silva + donos de processo

Sem. 12 · Fase 6 · Aditamentos de contratos com cláusulas LGPD · Responsável: Pedro Costa (Procuradoria)



MODELO 05 • GRUPO 1 • DOCUMENTOS FORMAIS

Aviso de Privacidade público

QUANDO USAR

Na Fase 6 do PGP. Documento público publicado no portal externo da Instituição. Cumpre o Art. 9º da LGPD (direito de informação ao titular). Recomenda-se 1 Aviso institucional + Avisos específicos pra serviços de alto impacto.

Template — Aviso institucional padrão

AVISO DE PRIVACIDADE — *[NOME DA INSTITUIÇÃO]*

Última atualização: *[DATA]*

01 Quem somos

[NOME DA INSTITUIÇÃO], inscrita no CNPJ sob nº *[CNPJ]*, com sede em *[ENDEREÇO]*, é o controlador dos dados pessoais tratados no âmbito de suas atribuições legais.

02 Por que tratamos seus dados

Tratamos dados pessoais pra *[FINALIDADES – ex: prestação de serviços públicos, atendimento ao cidadão, cumprimento de obrigações legais, execução de políticas públicas]*.

03 Quais dados tratamos

Dependendo do serviço utilizado, tratamos: *[LISTA – dados cadastrais (nome, CPF), de contato (e-mail, telefone), e eventualmente dados sensíveis quando o serviço exigir (ex: saúde nos atendimentos em UBS)]*.

04 Base legal do tratamento

Tratamos dados pessoais com base nas seguintes hipóteses da LGPD:

- ▶ Cumprimento de obrigação legal ou regulatória (Art. 7º II)
- ▶ Execução de políticas públicas previstas em leis e regulamentos (Art. 7º III)
- ▶ Execução de contrato (Art. 7º V) — quando há vínculo contratual
- ▶ Quando aplicável, tratamento de dados sensíveis com base no Art. 11

05 Por quanto tempo guardamos

Os prazos variam por categoria de dado. Em geral: dados de atendimento **[X anos]**, dados de saúde **[Y anos]**, dados fiscais **[Z anos]**. Após o prazo, anonimizamos ou eliminamos.

06 Como protegemos seus dados

Adotamos medidas técnicas e administrativas adequadas: controle de acesso por perfil, criptografia em trânsito, backup, logs de auditoria, treinamento da equipe. Operadores contratados (terceiros) têm cláusulas LGPD nos contratos.

07 Com quem compartilhamos

Compartilhamos dados apenas quando há previsão legal ou necessidade para cumprimento da finalidade — outros órgãos públicos no caso de execução de políticas públicas; operadores contratados sob cláusulas LGPD; autoridade judicial mediante requisição.

08 Transferência internacional

Indicar se há ou não. Se houver, especificar país e fundamento legal (Art. 33 LGPD).

09 Seus direitos como titular

Você pode exercer os direitos previstos no Art. 18 da LGPD:

- ▶ Confirmação da existência de tratamento
- ▶ Acesso aos dados tratados
- ▶ Correção de dados incompletos ou desatualizados
- ▶ Anonimização, bloqueio ou eliminação de dados desnecessários
- ▶ Portabilidade dos dados
- ▶ Informação sobre compartilhamento

- ▶ Revogação do consentimento (quando aplicável)

10 Canal de atendimento (DSR)

Pra exercer seus direitos ou esclarecer dúvidas sobre privacidade, fale com o(a) Encarregado(a) **[NOME DO ENCARREGADO]**: e-mail **[E-MAIL]**, telefone **[TELEFONE]**, atendimento presencial em **[ENDEREÇO]**. Prazo de resposta: 15 dias úteis (Art. 19 II LGPD).

11 Atualização deste Aviso

Este Aviso é revisado periodicamente. A data da última atualização aparece no topo. Mudanças significativas serão comunicadas.

EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

AVISO DE PRIVACIDADE — Prefeitura Municipal de Vegas

Última atualização: 15 de janeiro de 2027

Tratamos dados pessoais pra prestação de serviços públicos municipais nas áreas de saúde, educação, assistência social, tributação e ouvidoria. Base legal: Art. 7º III LGPD (políticas públicas) e Art. 11 II 'a' (obrigação legal) em dados sensíveis de saúde.

Canal de atendimento: Maria Silva (Encarregada) — [\[email protected\]](#) · (00) 0000-0000



Documento do PRI — Plano de Resposta a Incidentes

QUANDO USAR

Na Fase 7 do PGP, ANTES de qualquer incidente real. Define equipe responsável (ETIR/CSIRT), matriz RACI por etapa NIST e fluxos de resposta. Sem PRI pronto, o caos do incidente impede resposta tempestiva (3 dias úteis à ANPD).

Template — 8 seções

01 Identificação do órgão

[NOME DA INSTITUIÇÃO], CNPJ [CNPJ], com Encarregado(a) [NOME DO ENCARREGADO], contato [E-MAIL] / [TELEFONE].

02 Objetivo do PRI

Estabelecer procedimentos padronizados pra resposta a incidentes de segurança envolvendo dados pessoais, em cumprimento ao Art. 48 da LGPD e à Resolução CD/ANPD nº 15/2024.

03 Equipe de Tratamento de Incidentes (ETIR)

Composição mínima recomendada — preencher com nomes e contatos 24h:

DPO (Encarregado)	[NOME • E-MAIL • CELULAR 24h]
TI / Segurança	[NOME • E-MAIL • CELULAR 24h]
Jurídico	[NOME • E-MAIL • CELULAR 24h]
Comunicação	[NOME • E-MAIL • CELULAR 24h]

04 Detecção

Canais por onde incidentes podem ser identificados: SIEM/logs · denúncia interna · denúncia externa · notificação de operador · auditoria. Servidor que identificar comunica imediatamente o DPO pelo canal <[CANAL – ex: e-mail dpo@ + telefone (00) 0000-0000]>.

05 Contenção, Erradicação e Recuperação

Contenção (etapa CONTER): isolamento do sistema/processo afetado, bloqueio de credencial comprometida, revogação de acesso indevido.

Erradicação (etapa ERRADICAR): identificação da causa-raiz, aplicação de patches, fechamento da vulnerabilidade explorada.

Recuperação (etapa RECUPERAR): restauração a partir de backup íntegro, monitoramento reforçado pós-restauração, validação da operação.

06 Responsáveis pela comunicação

Comunicação à ANPD (Art. 48 + Res. 15/2024): elaborada pelo Encarregado em conjunto com Procuradoria; aprovada pela Alta Gestão antes do envio. Prazo: 3 dias úteis.

Comunicação aos titulares: elaborada pelo Encarregado + Comunicação Social; canal de envio compatível com o cadastro do titular. Prazo: 7 dias úteis (severidade ALTA/CRÍTICA).

07 Registro do incidente

Todo incidente, mesmo o de severidade BAIXA, deve ser registrado no sistema interno do Encarregado. Retenção mínima: 5 anos. Base legal: Art. 7º II LGPD.

08 Revisão e atualização do PRI

Este PRI é revisado anualmente OU após qualquer incidente de severidade ALTA/CRÍTICA OU em caso de mudança significativa no parque tecnológico/equipe.

Recomendado: simulado anual (tabletop exercise) com cenário plausível pra testar tempos de resposta e identificar lacunas.

EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Prefeitura Municipal de Vegas · Encarregada: Maria Silva — [\[email protected\]](#)
· (00) 0000-0001

ETIR: DPO Maria Silva (primário) · TI João Costa (suporte 24h) · Jurídico
Procuradoria-Geral (Dr. Pedro) · Alta Gestão (Prefeita Ana)

Detecção típica: SIEM dispara alerta · servidor identifica vazamento durante
auditoria · operador contratado comunica em 24h conforme cláusula

Última simulação tabletop: 12/03/2026 — cenário 'pendrive perdido com
500 prontuários'. Resultado: 18h até comunicação ANPD (dentro do prazo
legal).



Política do PGP (documento mater)

QUANDO USAR

Na Fase 5 do PGP. Documento institucional aprovado por ato formal do dirigente máximo. Cita os demais instrumentos do PGP como anexos vinculados. Revisão anual recomendada.

Template — 8 seções

01 Objetivo

Esta Política estabelece o Programa de Governança em Privacidade (PGP) de **[NOME DA INSTITUIÇÃO]**, em cumprimento à Lei nº 13.709/2018 — LGPD, regulamentando o tratamento de dados pessoais no âmbito de suas atividades.

02 Abrangência

Aplica-se a todas as unidades, servidores, estagiários, terceirizados e demais agentes que, no exercício de funções vinculadas a **[NOME DA INSTITUIÇÃO]**, realizem tratamento de dados pessoais sob qualquer forma e base legal.

03 Princípios

O tratamento observa os princípios do Art. 6º da LGPD: finalidade, adequação, necessidade, livre acesso, qualidade, transparência, segurança, prevenção, não discriminação e responsabilização.

04 Governança

O PGP é conduzido pelo(a) Encarregado(a) **[NOME DO ENCARREGADO]**, designado(a) por ato formal (Art. 41 LGPD), com apoio do Comitê de Privacidade — instância multidisciplinar com representantes das áreas **[ÁREAS – ex: TI, Jurídico,**

Comunicação, RH, áreas de negócio]. O Comitê reúne-se **[PERIODICIDADE – ex: mensalmente]**.

05 Instrumentos do PGP

Integram o PGP, como anexos vinculados:

- ▶ (a) Inventário de Tratamentos de Dados Pessoais
- ▶ (b) Análise de Riscos de Privacidade
- ▶ (c) Análise de Conformidade (GAP)
- ▶ (d) Plano de Ação
- ▶ (e) Relatórios de Impacto à Proteção de Dados (RIPD) dos processos de alto risco
- ▶ (f) Cadastro de Operadores com cláusulas LGPD
- ▶ (g) Canal e procedimento de exercício de Direitos do Titular (DSR)
- ▶ (h) Aviso de Privacidade público
- ▶ (i) Plano de Resposta a Incidentes (PRI)

06 Responsabilidades

Dirigente máximo: aprova o PGP, garante recursos, responde por sanções (Art. 52).

Encarregado: conduz operacionalmente, aceita reclamações, comunica-se com ANPD e titulares.

Comitê: delibera estrategicamente.

Gestores de área: aplicam as orientações.

Servidores: cumprem políticas, reportam incidentes.

Operadores (terceiros): cumprem cláusulas LGPD dos contratos.

07 Revisão

Esta Política é revisada anualmente ou antes em caso de: alteração legislativa · decisão da ANPD · incidente ALTA/CRÍTICA · reorganização institucional relevante.

08 Vigência

Esta Política entra em vigor na data de sua publicação em **[DIÁRIO OFICIAL ou EQUIVALENTE]** e revoga disposições em contrário.

[CIDADE], [DATA].

Dirigente máximo do órgão



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

POLÍTICA DO PGP — Prefeitura Municipal de Vegas

Encarregada: Maria Silva (Procuradoria-Adjunta). Comitê: 7 membros (TI/Jurídico/Comunicação/RH/Saúde/Tributário/Assistência Social).

Reuniões mensais na 1ª terça-feira do mês.

Aprovado pelo Decreto Municipal nº 042/2027, de 15 de fevereiro de 2027 — Prefeita Ana Costa.



Cláusulas LGPD pra contratos (aditamento padrão)

QUANDO USAR

Pra incluir em contratos novos OU aditar contratos vigentes com operadores (terceiros que tratam dados pessoais em nome da Instituição). Atende o Art. 39 LGPD. Em contratos antigos pré-2020 sem cláusulas LGPD, promover aditamento gradualmente.

Template — 8 cláusulas mínimas (Art. 39 LGPD)

As cláusulas abaixo devem ser incluídas em todos os contratos com operadores. Adaptar redação às minutas-padrão da Procuradoria.

CLÁUSULA 1

Objeto do tratamento

O OPERADOR realizará tratamento de dados pessoais exclusivamente para os fins descritos no objeto principal deste contrato, ficando vedado qualquer tratamento estranho a esse escopo, salvo expressa autorização prévia e por escrito da CONTRATANTE.

CLÁUSULA 2

Segurança e confidencialidade

O OPERADOR adotará medidas técnicas e administrativas adequadas para proteger os dados pessoais contra acessos não autorizados, perdas acidentais, alterações indevidas ou divulgação inadequada, em conformidade com os Arts. 46 a 49 da LGPD.

CLÁUSULA 3

Comunicação de incidentes

O OPERADOR comunicará à CONTRATANTE, imediatamente após o conhecimento e em prazo não superior a 24 (vinte e quatro) horas, qualquer incidente de

segurança envolvendo dados pessoais sob seu tratamento, fornecendo informações pra subsidiar a comunicação à ANPD e aos titulares.

CLÁUSULA 4

Subcontratação

O OPERADOR não subcontratará terceiros para o tratamento sem prévia autorização escrita da CONTRATANTE. Em caso de autorização, o sub-operador assumirá as mesmas obrigações deste contrato por instrumento escrito.

CLÁUSULA 5

Direitos dos titulares

O OPERADOR auxiliará a CONTRATANTE no atendimento das solicitações dos titulares (Art. 18 LGPD), em prazo não superior a 5 (cinco) dias úteis a contar da requisição.

CLÁUSULA 6

Retenção e devolução/destruição

Encerrada a relação contratual, o OPERADOR devolverá à CONTRATANTE ou destruirá, conforme orientação desta, todos os dados pessoais sob seu tratamento, em prazo não superior a 30 (trinta) dias, salvo determinação legal em contrário.

CLÁUSULA 7

Auditoria

A CONTRATANTE poderá, mediante aviso prévio de 15 dias úteis, realizar auditoria das medidas de segurança implementadas pelo OPERADOR, diretamente ou por terceiro independente.

CLÁUSULA 8

Responsabilidade

O OPERADOR responde civilmente pelos danos decorrentes do descumprimento das obrigações deste contrato, nos termos do Art. 42 da LGPD, sem prejuízo das sanções administrativas e judiciais cabíveis.

COMO APLICAR EM CONTRATOS ANTIGOS

Promover TERMO ADITIVO ao contrato, sem necessidade de rescisão.

Cabeçalho do aditivo: 'Termo Aditivo nº X — Inclusão de Cláusulas LGPD ao

Contrato nº Y'. Anexar este conjunto de 8 cláusulas. Assinatura de ambas as partes.



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

TERMO ADITIVO Nº 02 — Inclusão de Cláusulas LGPD ao Contrato nº 045/2024

Pelo presente Termo, a Prefeitura Municipal de Vegas e a Empresa Hipotética Tecnologia LTDA (CNPJ 00.000.000/0001-00) aditam o Contrato nº 045/2024 (objeto: hospedagem do sistema de Ouvidoria) pra incluir as Cláusulas LGPD do Art. 39 da Lei 13.709/2018, vigentes a partir desta data.

Vegas, 15 de março de 2027. Prefeita Ana Costa / Diretor Empresa Hipotética.



Política de Retenção e Descarte de Dados Pessoais

QUANDO USAR

Na Fase 6 do PGP. Define prazos de retenção por categoria de dado e procedimento de descarte seguro. Cumpre o Art. 16 da LGPD. Revisão anual recomendada.

Template

01 Princípio geral

Os dados pessoais não são mantidos por tempo superior ao necessário ao cumprimento da finalidade. Findo o tratamento, devem ser eliminados, anonimizados ou ter retenção justificada em hipótese legal específica (Art. 16 LGPD).

02 Hipóteses que autorizam retenção (Art. 16)

- ▶ Cumprimento de obrigação legal ou regulatória
- ▶ Estudo por órgão de pesquisa (com anonimização sempre que possível)
- ▶ Transferência a terceiro respeitada a Lei
- ▶ Uso exclusivo do controlador, com anonimização

03 Tabela de prazos por categoria — preencher

Adaptar prazos à realidade institucional e à legislação setorial aplicável:

Dados de servidores ativos	<i>[durante o vínculo + prazo previdenciário – geralmente até 75 anos]</i>
Dados de servidores inativos / pensionistas	<i>[durante pagamento de benefícios + prazo previdenciário]</i>

Candidatos não selecionados em seleções	<i>[1 ano após término da validade do edital]</i>
Atendimento ao cidadão / Ouvidoria	<i>[5 anos – prazo prescricional padrão]</i>
Dados de saúde (prontuários)	<i>[20 anos da última consulta – CFM Res. 1.821/2007]</i>
Dados fiscais / tributários	<i>[5 anos – legislação tributária]</i>
Logs de acesso a sistemas	<i>[6 meses a 5 anos – conforme criticidade]</i>
Imagens de CFTV	<i>[30 a 90 dias, salvo investigação em curso]</i>
Licitantes não vencedores	<i>[5 anos após encerramento do certame]</i>

04 Procedimento de descarte

Documental: fragmentação ou incineração com registro em termo.

Digital: exclusão lógica + sobrescrita ou descarte físico do meio.

Em ambos os casos, lavrar termo de descarte com data, responsável e categoria descartada. Reter o termo pelo prazo prescricional aplicável.

05 Anonimização como alternativa

Quando viável, anonimizar em vez de descartar (Art. 12 LGPD) — dado anonimizado sai do escopo da LGPD. Anonimização precisa ser irreversível (não basta pseudonimização).

06 Revisão

Esta Política é revisada anualmente, especialmente pra adequar prazos a alterações legislativas e novos sistemas implantados.



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

POLÍTICA DE RETENÇÃO — Prefeitura Municipal de Vegas

Dados de servidores ativos: durante o vínculo + 75 anos (Lei nº 9.717/1998 — previdenciária).

Dados de Ouvidoria: 5 anos (prazo prescricional padrão da AdmPub).

Prontuários médicos: 20 anos da última consulta (Resolução CFM nº 1.821/2007).

Anonimização aplicada aos dados de saúde após 20 anos (estatística agregada — fora do escopo LGPD).



Termo de Consentimento do Titular

QUANDO USAR

APENAS em tratamentos FACULTATIVOS do ponto de vista do cidadão (ex: cadastro voluntário em newsletter institucional, autorização pra uso de imagem em material promocional). NO SETOR PÚBLICO, consentimento é base legal EXCEPCIONAL — a regra é Art. 7º II (obrigação legal) ou Art. 7º III (política pública). Consentimento exige possibilidade REAL de recusa sem prejuízo do serviço público principal.

Template

TERMO DE CONSENTIMENTO PARA TRATAMENTO DE DADOS PESSOAIS	<i>[NOME DA INSTITUIÇÃO]</i> , inscrita no CNPJ sob nº <i>[CNPJ]</i> , com sede em <i>[ENDEREÇO]</i> , na qualidade de Controlador (Art. 5º VI LGPD), solicita o consentimento de <i>[NOME DO TITULAR]</i> para o tratamento dos seguintes dados pessoais:
Dados tratados	<i>[LISTA ESPECÍFICA – ex: nome, e-mail, telefone, imagem em vídeo de evento]</i>
Finalidade	<i>[ESPECÍFICA – ex: envio de informativo institucional mensal sobre eventos culturais]</i>
Prazo de retenção	<i>[ESPECÍFICO – ex: até que o titular solicite descadastro]</i>
Compartilhamentos	<i>[se houver, ESPECIFICAR – ex: empresa contratada pra hospedagem do mailing – nome + cláusulas LGPD]</i>

Direitos do titular

O titular pode, a qualquer tempo, revogar este consentimento e exercer os direitos do Art. 18 da LGPD (acesso, correção, anonimização, eliminação, portabilidade,

oposição, informações sobre compartilhamento), pelo canal: **[E-MAIL DO ENCARREGADO]**.

Declaração

Declaro ter sido informado(a) sobre o tratamento dos meus dados pessoais e concordo livremente, de forma específica e inequívoca (Art. 5º XII LGPD), com o tratamento descrito acima.

Local, data: **[CIDADE]**, **[DATA]**.

Assinatura do(a) titular

VALIDADE DO CONSENTIMENTO

Consentimento marcado por padrão (opt-out) é INVÁLIDO (Art. 8º). Caixa de aceite deve estar DESMARCADA por padrão — titular marca se quiser (opt-in real). Consentimento revogado a qualquer momento pelo canal DSR.

EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

TERMO DE CONSENTIMENTO — Prefeitura Municipal de Vegas

Dados: nome + e-mail. Finalidade: envio de newsletter mensal sobre eventos culturais municipais. Prazo: até descadastro. Compartilhamento: nenhum.

Titular: João Silva. Canal DSR: [\[email protected\]](#).

Assinatura digital, 15 de janeiro de 2027.



Comunicação de Incidente à ANPD

QUANDO USAR

Em até 3 dias úteis após o conhecimento de incidente de severidade ALTA ou CRÍTICA (Art. 48 LGPD + Resolução CD/ANPD nº 15/2024). Submeter via portal da ANPD (gov.br/anpd → Comunicações).

Template — campos obrigatórios

01 Identificação do controlador

Nome do órgão	[NOME DA INSTITUIÇÃO]
CNPJ	[CNPJ]
Endereço	[ENDEREÇO COMPLETO]
Nome do Encarregado	[NOME DO ENCARREGADO]
E-mail do Encarregado	[E-MAIL]
Telefone do Encarregado	[TELEFONE]

02 Quando ocorreu / foi detectado

Data e hora aproximada da ocorrência	[DATA + HORA – se conhecida; senão indicar 'desconhecida']
Data e hora da detecção pelo controlador	[DATA + HORA]
Data desta comunicação	[DATA + HORA]

03

Descrição do incidente

[DESCRIÇÃO DA NATUREZA DO INCIDENTE – vazamento por acesso indevido? perda de dispositivo? ataque externo? falha em sistema? Detalhar de forma objetiva, sem juízo de valor.]

04 Natureza dos dados afetados

Marcar todas as categorias aplicáveis:

- ▶ ☐ Dados cadastrais (nome, CPF, RG, endereço)
- ▶ ☐ Dados de contato (e-mail, telefone)
- ▶ ☐ Dados financeiros (conta bancária, salário, transações)
- ▶ ☐ Dados de saúde
- ▶ ☐ Outros dados sensíveis (Art. 5º II) — especificar
- ▶ ☐ Dados de crianças/adolescentes
- ▶ ☐ Outros — especificar

05 Categorias e número de titulares afetados

Categorias	<i>[ex: servidores ativos, cidadãos atendidos, fornecedores]</i>
Número aproximado	<i>[ex: 250 servidores]</i>

06 Medidas de segurança que estavam em uso

[DESCRIÇÃO DAS MEDIDAS QUE EXISTIAM ANTES DO INCIDENTE – controle de acesso, criptografia, backup, treinamento, etc.]

07 Riscos relacionados ao incidente

[ANÁLISE DOS RISCOS – danos morais aos titulares, exposição financeira, discriminação, etc.]

08 Medidas adotadas para mitigar

- ▶ ☐ Isolamento do sistema/processo afetado
- ▶ ☐ Revogação de credenciais comprometidas
- ▶ ☐ Aplicação de patches/correções

- ▶ ☐ Restauração a partir de backup íntegro
- ▶ ☐ Apuração disciplinar (se aplicável)
- ▶ ☐ Notificação individual aos titulares afetados
- ▶ ☐ Revisão dos perfis de acesso
- ▶ ☐ Outras — especificar

09 Motivo do atraso (se aplicável)

[SE A COMUNICAÇÃO NÃO FOI EM ATÉ 3 DIAS ÚTEIS – justificar com base técnica/operacional]

10 Identificação do responsável pela comunicação

Nome: *[NOME DO ENCARREGADO]*

Cargo: *[CARGO]*

Data e assinatura: *[DATA], [CIDADE].*



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Comunicação à ANPD — Incidente de 15/03/2027

Controlador: Prefeitura Municipal de Vegas. Encarregada: Maria Silva — [\[email protected\]](#).

Detecção: 18/03/2027 — auditoria identificou cópia local não-autorizada de planilha contendo dados de 250 servidores (CPF, conta bancária).

Mitigação: acesso do servidor revogado em 30 minutos · planilha excluída · apuração disciplinar instaurada · todos os 250 titulares notificados em até 7 dias úteis.

Encarregada Maria Silva — comunicação submetida em 20/03/2027 às 16h.



Comunicação de Incidente aos Titulares

QUANDO USAR

Em até 7 dias úteis após o conhecimento de incidente de severidade ALTA ou CRÍTICA, conforme Art. 48 LGPD + Res. CD/ANPD nº 15/2024.

Comunicar pelo canal mais compatível com o cadastro do titular (e-mail, carta, SMS, telefone).

Template — Modelo de carta/e-mail

Prezado(a) **[NOME DO TITULAR]**,

Em cumprimento ao dever de transparência previsto na Lei Geral de Proteção de Dados Pessoais — LGPD (Lei nº 13.709/2018, Art. 48), comunicamos a ocorrência de incidente de segurança envolvendo dados pessoais sob nossa responsabilidade que afetou dados de sua titularidade.

O que aconteceu

Em **[DATA DA OCORRÊNCIA]**, identificamos **[DESCRIÇÃO BREVE DO INCIDENTE — em linguagem clara, sem jargão técnico. Ex: 'acesso não autorizado a uma planilha contendo dados pessoais de servidores municipais']**.

Quais dados seus foram afetados

Os dados envolvidos no incidente, referentes a você, foram: **[LISTAR DADOS ESPECÍFICOS — ex: nome completo, CPF, dados bancários]**.

O que estamos fazendo

Adotamos as seguintes medidas pra mitigar o ocorrido e evitar novos incidentes:

[LISTAR MEDIDAS — ex: 'revogamos imediatamente o acesso indevido', 'instauramos procedimento de apuração', 'revisamos os perfis de acesso aos

sistemas', 'comunicamos o incidente à Autoridade Nacional de Proteção de Dados (ANPD) '].

O que você pode fazer

Recomendamos que você, como medida preventiva, considere:

- ▶ Monitorar movimentações em suas contas bancárias e cadastros (se aplicável aos dados afetados)
- ▶ Manter atenção a tentativas de fraude que possam usar essas informações
- ▶ Entrar em contato conosco pelo canal abaixo em caso de dúvidas ou suspeitas

Como falar conosco

O(A) Encarregado(a) **[NOME DO ENCARREGADO]** está disponível pra esclarecer dúvidas e atender solicitações:

E-mail: **[E-MAIL]**

Telefone: **[TELEFONE]**

Atendimento presencial: **[ENDEREÇO]**

Reiteramos nosso compromisso com a proteção de seus dados pessoais e nos colocamos à disposição pra esclarecimentos.

Respeitosamente,

[NOME DO ENCARREGADO]

**Encarregado(a) pelo
Tratamento de Dados
Pessoais**

[NOME DA INSTITUIÇÃO]



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Prezada Sra. Joana da Silva,

Em 15/03/2027 identificamos acesso não autorizado a uma planilha contendo dados de servidores municipais. Os dados afetados, referentes a você, foram: nome completo, CPF, conta bancária utilizada pra recebimento de salário.

Medidas: revogamos o acesso indevido em 30 minutos · planilha removida ·
apuração instaurada · ANPD comunicada em 3 dias úteis.

Recomendamos monitorar sua conta bancária. Em dúvidas, fale com Maria
Silva (Encarregada) — [\[email protected\]](#) · (00) 0000-0001.

Prefeitura Municipal de Vegas.



Termômetro — auto-diagnóstico (você + sua Instituição)

QUANDO USAR

Na Fase Preliminar, como linha de base, e periodicamente (semestral/anual) pra evidenciar a evolução. São 2 blocos com scores SEPARADOS: a Parte 1 mede o conhecimento de CADA PESSOA sobre a LGPD (aplicar individualmente — ex.: antes e depois de capacitações internas); a Parte 2 mede em que etapa da jornada de adequação a INSTITUIÇÃO está — uma pergunta por etapa do PGP (responder em consenso pela equipe do PGP, ou tirar a média das respostas individuais).

Parte 1 — Sobre você (3 perguntas)

 Qual o seu contato com a LGPD até hoje?

[MARCAR – Nunca ouvi falar (5) • Já ouvi falar (10) • Conheço o básico (15) • Conheço bem (20)]

 No seu trabalho, você saberia dizer o que pode e o que não pode fazer com dados de pessoas?

[MARCAR – Ainda não saberia (5) • Só intuição (10) • Sei o essencial (15) • Sei com segurança (20)]

 Se acontecer um problema com dados pessoais (vazamento, reclamação de cidadão), você sabe o que fazer?

[MARCAR – Não faria ideia (5) • Avisaria o chefe (10) • Sei os primeiros passos (15) • Sei o procedimento (20)]

Score pessoal (0-100) = soma dos pontos ÷ 60 × 100 = *[SCORE]*



Parte 2 — Sobre a sua Instituição (7 perguntas — uma por etapa do PGP)



Os chefes (prefeito/presidente, secretários, diretores) compram a ideia de proteger dados?

[MARCAR – Não olham pra isso (5) • Acham importante (10) • Apoiam oficialmente (15) • Puxam o tema (20)]

 Tem alguém responsável por proteção de dados no órgão?	<i>[MARCAR – Ninguém ainda (5) • Alguém informal (10) • Nomeado oficialmente (15) • Responsável + equipe (20)]</i>
 Vocês sabem quais dados de pessoas o órgão usa e onde ficam guardados?	<i>[MARCAR – Ainda não levantamos (5) • Só uma noção (10) • Principais mapeados (15) • Mapa completo (20)]</i>



Vocês avaliam os riscos antes de usar dados delicados (saúde, crianças, etc.)?

[MARCAR – Sem esse hábito (5) • Só quando salta aos olhos (10) • Nos casos delicados (15) • Método padrão (20)]



Vocês já compararam o que fazem hoje com o que a Lei exige, pra achar o que falta?

[MARCAR – Não sabemos o que falta (5) • Ideia geral (10) • Levantamento feito (15) • Lista priorizada (20)]

 Existe um plano com prazos pra resolver o que falta — e ele sai do papel?	<i>[MARCAR – Sem plano ainda (5) • Boas intenções (10) • Plano escrito (15) • Em execução (20)]</i>
 Depois de ajustar, vocês acompanham e revisam de tempos em tempos?	<i>[MARCAR – Não revisamos (5) • Só quando dá problema (10) • Revisão combinada (15) • Com indicadores (20)]</i>

Score institucional (0-100) = soma dos pontos ÷ 140 × 100 = **[SCORE]**

Faixas do score pessoal (conhecimento)

- ▶ 80-100 — Multiplicador (Domínio forte — você pode orientar colegas)
- ▶ 60-79 — Bom domínio (Você navega bem pelo tema no dia-a-dia)
- ▶ 40-59 — Conhecimento em construção (Base formada — faltam as conexões com a prática)

- ▶ 20-39 — Conhecimento inicial (Já ouviu os termos — agora é organizar as ideias)
- ▶ 0-19 — Primeiro contato (Você está começando agora — o curso é exatamente pra isso)

Faixas do score institucional (maturidade)

- ▶ 80-100 — Maturidade Avançada (Órgão referência — adequação consolidada com cultura forte)
- ▶ 60-79 — Maturidade Estabelecida (Boa base institucional — falta consolidar práticas em alguns pontos)
- ▶ 40-59 — Maturidade em Desenvolvimento (Caminho iniciado — precisa estruturar mais o trabalho)
- ▶ 20-39 — Maturidade Inicial (Pontos de partida identificados — agora é começar com método)
- ▶ 0-19 — Diagnóstico de Partida (Quase nada estruturado — exatamente por isso estão aqui)

Aplicação realizada em: **[DATA]** · Aplicado por: **[NOME – opcional]**



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Aplicação em 15/01/2027 — servidor(a) da Prefeitura Municipal de Vegas:

Parte 1 (você): $10 + 10 + 5 = 25$ pontos $\rightarrow 25 \div 60 \times 100 =$ score pessoal 42/100 — Conhecimento em construção.

Parte 2 (instituição): $10 + 10 + 10 + 5 + 5 + 5 + 5 = 50$ pontos $\rightarrow 50 \div 140 \times 100 =$ score institucional 36/100 — Maturidade Inicial.

Reaplicar em 6 meses pra acompanhar a evolução dos 2 scores.



Matriz de Priorização de Processos (Res. CD/ANPD nº 2/2022)

QUANDO USAR

Na Fase 2 do PGP, pra priorizar quais processos entram primeiro no Inventário detalhado da Fase 3. Aplicar a cada processo identificado. Score 0-18 (1-3 pontos por critério × 6 critérios).

Formulário pra preencher por processo

Processo avaliado: **[NOME DO PROCESSO]**

 Volume de titulares	<i>[Baixo 1 = até 100 / Médio 2 = 100-1.000 / Alto 3 = +1.000]</i>
 Sensibilidade dos dados	<i>[Baixo 1 = cadastrais / Médio 2 = financeiros, comportamentais / Alto 3 = sensíveis Art. 5º II]</i>
 Vulnerabilidade dos titulares	<i>[Baixo 1 = apenas adultos / Médio 2 = eventualmente vulneráveis / Alto 3 = sistematicamente menores/idosos]</i>
 Exposição pública	<i>[Baixo 1 = restrito / Médio 2 = compartilhamento limitado / Alto 3 = publicação ampla]</i>
 Tecnologias inovadoras	<i>[Baixo 1 = planilhas / Médio 2 = sistemas convencionais / Alto 3 = IA, biometria, decisões automatizadas]</i>
 Compartilhamentos com terceiros	<i>[Baixo 1 = nenhum/interno / Médio 2 = 1-2 operadores / Alto 3 = múltiplos ou transferência internacional]</i>

Score total do processo: **[SOMA 0-18]**

Faixas: 0-6 BAIXA prioridade · 7-12 MÉDIA · 13-18 ALTA

Justificativa: *[Comentário curto explicando a pontuação – opcional mas recomendado]*

Ranking dos processos

Após pontuar todos os processos, ordenar do maior score pro menor. Os 5-10 primeiros entram no Inventário detalhado da Fase 3.



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Processo: Atendimento no Posto de Saúde Dr. Joaquim Bento

Volume 3 (Alto · ~24mil/ano) · Sensibilidade 3 (Alto · dados de saúde) ·
Vulneráveis 2 (Médio · idosos eventualmente) · Exposição 1 (Baixo · restrito)
· Tecnologias 2 (Médio · sistema convencional) · Compartilhamentos 2
(Médio · ESUS-DAB federal)

Score: 13/18 = ALTA prioridade.

Justificativa: alto volume + dados de saúde sensíveis. Entra como prioridade nº 1 no Inventário.



MODELO 15 • GRUPO 3 • FICHAS OPERACIONAIS

Ficha de Processo (Inventário)

QUANDO USAR

Na Fase 3 do PGP, pra cada processo de tratamento mapeado. Documenta o ciclo completo: titulares, dados, finalidade, base legal, retenção, compartilhamentos, medidas. Reproduzir 1 ficha por processo.

Formulário

Nome do processo	[NOME – ex: Atendimento no Posto de Saúde]
Setor responsável	[SETOR – ex: Secretaria Municipal de Saúde]
Dono do processo	[CARGO – ex: Gerente do Posto Central]
Categorias de titulares	[ex: cidadãos atendidos • responsáveis de menores • servidores envolvidos]
Tipos de dados coletados	[lista granular – ex: nome, CPF, endereço, telefone, prontuário, prescrições]
Dados sensíveis?	[Sim/Não – se sim, listar quais: saúde / opinião política / etc.]
Finalidade	[descrição clara e específica]
Base legal (Art. 7º e/ou Art. 11)	[ex: Art. 7º III (políticas públicas) + Art. 11 II 'a' (saúde)]
Como os dados são coletados	[ex: formulário físico no balcão + cadastro no sistema Saúde+]
Onde são armazenados	[ex: sistema Saúde+ (hospedado em data center municipal) + arquivo físico de

	<i>fichas]</i>
Quem tem acesso	<i>[perfis: médico, enfermeiro, recepção, gestor – segregação por perfil]</i>
Compartilhamentos internos	<i>[outros setores do órgão que recebem]</i>
Compartilhamentos externos (operadores/órgãos)	<i>[empresas contratadas, outros órgãos públicos – com cláusulas LGPD]</i>
Prazo de retenção	<i>[ex: 20 anos da última consulta – CFM Res. 1.821/2007]</i>
Procedimento de descarte	<i>[ex: anonimização após 20 anos / fragmentação física dos prontuários]</i>
Medidas de segurança técnicas	<i>[ex: login individual + perfil + logs + backup criptografado]</i>
Medidas administrativas	<i>[ex: treinamento anual obrigatório, termo de responsabilidade individual]</i>
Aprovado pelo DPO em	<i>[DATA – após revisão]</i>



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Processo: Atendimento no Posto de Saúde Dr. Joaquim Bento · Setor: SMS ·
Dono: Dra. Ana (Gerente)

Titulares: cidadãos atendidos (~24mil/ano) + responsáveis de menores.
Dados: cadastrais + sensíveis de saúde (prontuário, prescrições, exames).

Base legal: Art. 7º III (políticas públicas — SUS) + Art. 11 II 'a' (tutela da saúde).

Sistema Saúde+ (DC municipal) + prontuário físico. Acesso por perfil (médico/enfermeiro/recepção).

Retenção: 20 anos da última consulta. Descarte: anonimização agregada pra estatística + fragmentação dos físicos.

Aprovado por Maria Silva (Encarregada) em 15/04/2027.



Ficha de Risco com matriz P × I

QUANDO USAR

Na Fase 3 do PGP, junto do Inventário. Pra cada processo, identificar 2-4 riscos principais. Classificar Probabilidade × Impacto na matriz 3x3 (Baixa/Média/Alta).

Formulário

Risco — título curto	<i>[NOME — ex: Acesso indevido por servidor sem necessidade funcional]</i>
Processo relacionado	<i>[NOME DO PROCESSO]</i>
Categoria do risco	<i>[Confidencialidade / Integridade / Disponibilidade / Princípio da finalidade / Outro]</i>
Descrição (cenário concreto)	<i>[Cenário plausível — quem faz o quê, com qual consequência ao titular]</i>
Probabilidade	<i>[BAIXA / MÉDIA / ALTA]</i>
Impacto	<i>[BAIXO / MÉDIO / ALTO]</i>
Severidade resultante	<i>[Da matriz 3x3 — BAIXO / MÉDIO / ALTO]</i>
Medidas de mitigação propostas	<i>[Ações concretas pra reduzir probabilidade ou impacto]</i>
Responsável pela mitigação	<i>[NOME ou setor]</i>
Prazo de implementação	<i>[DATA esperada]</i>
Risco residual após mitigação	<i>[BAIXO / MÉDIO — aceitável; ALTO = exige escalada]</i>

Matriz 3x3 de referência

Probabilidade × Impacto → Severidade:

- ▶ Baixa × Baixo = BAIXO · Baixa × Médio = BAIXO · Baixa × Alto = MÉDIO
- ▶ Média × Baixo = BAIXO · Média × Médio = MÉDIO · Média × Alto = ALTO
- ▶ Alta × Baixo = MÉDIO · Alta × Médio = ALTO · Alta × Alto = ALTO



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Risco: Acesso indevido à folha de pagamento por servidor não-autorizado ·

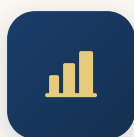
Processo: Folha de Pagamento · Categoria: Princípio da finalidade.

Cenário: servidor com acesso amplo consulta dados de colegas por curiosidade.

Probabilidade ALTA × Impacto MÉDIO = Severidade ALTA.

Mitigação: revisão de perfis (princípio do menor privilégio) · ativação de logs de consulta · auditoria trimestral · treinamento + termo individual de responsabilidade.

Responsável: TI + RH. Prazo: 30 dias. Risco residual esperado: BAIXO.



GAP — Planilha de Avaliação de Controles

QUANDO USAR

Na Fase 4 do PGP. Pra cada controle do catálogo, a Instituição se classifica em ADERENTE / PARCIAL / NÃO ADERENTE com justificativa. Cada NÃO ADERENTE vira ação no Plano (Fase 5).

Formulário — por controle

ID do controle	<i>[1-30 do pacote do curso – ou referência do catálogo institucional]</i>
Texto do controle	<i>[ex: Encarregado (DPO) designado por ato formal e publicado]</i>
Área / Fase do PGP	<i>[ex: Fase 1 – Governança]</i>
Classificação	<i>[ADERENTE / PARCIAL / NÃO ADERENTE / APOIO PENDENTE]</i>
Justificativa	<i>[Explicação técnica/objetiva da classificação]</i>
Evidências	<i>[Documentos, sistemas, processos que comprovam a aderência]</i>
Setor de apoio (se APOIO PENDENTE)	<i>[TI / Jurídico / Comunicação / RH / etc.]</i>
Avaliado por	<i>[NOME do Encarregado ou Comitê]</i>
Data da avaliação	<i>[DATA]</i>

Pontuação consolidada do GAP

Score = ((aderentes × 100) + (parciais × 50)) / (total avaliado × 100)

Avaliados = aderentes + parciais + não-aderentes (APOIO PENDENTE não conta no denominador)

Faixa: ≥80% maturidade alta · 60-79 média · 40-59 em construção · <40 inicial



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Controle 04 (Fase 1) · Encarregado designado por ato formal · ADERENTE ·
Justificativa: Portaria nº 03/2026 publicada no DOM-Vegas em 15/03/2026
· Evidências: cópia da Portaria + contatos no portal · Avaliado por: Maria
Silva em 20/04/2027.

Controle 22 (Fase 6) · Cláusulas LGPD em contratos com operadores · NÃO
ADERENTE · Justificativa: 30 contratos vigentes; só 5 têm cláusulas.
Aditamento em andamento pelos demais · Evidência: lista de contratos da
Administração · Vira ação no Plano (prazo 90 dias).



Plano de Ação

QUANDO USAR

Na Fase 5 do PGP. Cada controle NÃO ADERENTE do GAP + cada risco ALTO vira uma ação no Plano. Acompanhamento mensal pelo Comitê de Privacidade.

Formulário — por ação

Ação	<i>[Descrição clara e específica do que será feito]</i>
Origem	<i>[GAP / RISCO / DIAGNÓSTICO / MANUAL]</i>
Referência (ID)	<i>[ID do controle GAP ou risco que originou]</i>
Responsável	<i>[NOME e/ou SETOR responsável]</i>
Prioridade	<i>[BAIXA / MÉDIA / ALTA]</i>
Prazo	<i>[DATA esperada]</i>
Status atual	<i>[ABERTA / EM ANDAMENTO / CONCLUÍDA]</i>
Evidência de conclusão	<i>[Preencher quando concluída]</i>
Observações	<i>[Eventuais bloqueios, dependências, decisões do Comitê]</i>

Boas práticas do Plano

- ▶ Cada ação com responsável NOMEADO (não setor genérico). Sem nome, não anda.
- ▶ Prazo realista — não defina prazos heróicos que ninguém vai cumprir.

- ▶ Acompanhamento MENSAL pelo Comitê de Privacidade — pauta fixa de revisão.
- ▶ Ações concluídas devem ser ARQUIVADAS (não excluídas) — vira histórico institucional.
- ▶ Ações com mais de 3 meses sem progresso → reavaliar viabilidade ou repriorizar.



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Ação: Promover aditivo contratual com cláusulas LGPD em 30 contratos vigentes pré-2020.

Origem: GAP (controle 22). Responsável: Pedro Costa (Procuradoria).
Prioridade ALTA. Prazo: 90 dias. Status: EM ANDAMENTO (10/30 concluídos).

Observação: priorizar contratos com operadores que tratam dados sensíveis ou em larga escala.



RIPD — Relatório de Impacto à Proteção de Dados

QUANDO USAR

Na Fase 6 do PGP, pra processos de ALTO RISCO (Art. 38 LGPD): dados sensíveis em larga escala, vigilância sistemática, decisões automatizadas, dados de crianças/adolescentes, tecnologias inovadoras. Reproduzir 1 RIPD por processo crítico.

Template — 8 seções

RIPD — *[NOME DO PROCESSO]*

SEÇÃO 1

Identificação do controlador e do Encarregado

Controlador: *[NOME DA INSTITUIÇÃO]*, CNPJ *[CNPJ]*. Encarregado(a): *[NOME]*, contatos *[E-MAIL/TELEFONE]*. Operadores envolvidos: *[LISTAR – empresas/órgãos que processam dados em nome do controlador, com referência aos contratos]*.

SEÇÃO 2

Descrição do tratamento e finalidades

[DESCREVER – natureza do tratamento, finalidades específicas, categorias de titulares afetados, fluxos de dados (origem → tratamento → destino)].

SEÇÃO 3

Necessidade e proporcionalidade

[JUSTIFICAR – por que os dados tratados são os ESTRITAMENTE necessários à finalidade? Há alternativa menos invasiva à privacidade que cumpra a mesma finalidade?]

SEÇÃO 4

Riscos identificados aos direitos dos titulares

[LISTAR – riscos concretos pros titulares: vazamento por acesso indevido, uso para fim incompatível, decisão automatizada equivocada, discriminação, etc.]

SEÇÃO 5

Medidas de segurança e mitigação

[DESCREVER MEDIDAS – técnicas (criptografia, controle de acesso, logs, backup) + administrativas (treinamento, termo de responsabilidade, política interna)].

SEÇÃO 6

Mecanismos pra exercício de direitos do titular

Canal DSR pra este processo: *[E-MAIL/FORMULÁRIO/TELEFONE]*. Prazo de resposta: 15 dias úteis (Art. 19 II LGPD). Documentar como cada direito do Art. 18 é operacionalmente atendido.

SEÇÃO 7

Decisão e responsabilidades

[O TRATAMENTO É APROVADO? Sim/Não/Condicional. Quais condições? Quem assina? Responsabilidades dos atores envolvidos (DPO, dono do processo, TI, operadores).]

SEÇÃO 8

Revisão e atualização

Este RIPD será revisado em <*[PRAZO – recomendado anual]*> ou antes em caso de: mudança significativa no fluxo · novo sistema · novo operador · alteração legislativa · incidente relevante.

[CIDADE], [DATA].

[NOME DO ENCARREGADO]

Encarregado(a) pelo Tratamento de Dados Pessoais



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

RIPD — Atendimento no Posto de Saúde Dr. Joaquim Bento

Controlador: PM Vegas. Encarregada: Maria Silva. Operadores: empresa de TI hospedando o sistema Saúde+ (contrato 022/2024 com cláusulas LGPD).

Tratamento: prontuário eletrônico, agendamento, exames. ~24mil titulares/ano, dados sensíveis de saúde.

Riscos: vazamento por acesso indevido · acesso por servidor sem necessidade funcional · perda do banco em falha técnica.

Mitigação: login individual + segregação por perfil + logs + backup criptografado + treinamento anual + termo de responsabilidade.

Aprovado pela Encarregada em 20/05/2027. Próxima revisão: 20/05/2028.



MODELO 20 • GRUPO 3 • FICHAS OPERACIONAIS

Ficha de Operador (Terceiro)

QUANDO USAR

Na Fase 6 do PGP, pra cada operador (terceiro que trata dados em nome da Instituição). Mantém registro centralizado dos contratos com cláusulas LGPD e do nível de risco. Reproduzir 1 ficha por operador.

Formulário

Nome do operador	[NOME DA EMPRESA/ÓRGÃO]
CNPJ	[CNPJ]
Serviço prestado	[DESCRIÇÃO – ex: hospedagem do sistema de ouvidoria]
Papel LGPD	[OPERADOR / CONTROLADOR CONJUNTO]
Contrato nº	[NÚMERO/ANO]
Objeto do contrato	[DESCRIÇÃO RESUMIDA]
Vigência (início – fim)	[DATA – DATA]
Cláusulas LGPD incluídas?	[SIM / NÃO / EM ADITAMENTO]
Tipo de operação contratual	[CONTRATO_NOVO_CLAUSULAS / RENOVACAO_ADITIVAR / ADITIVO_NECESSARIO]
Nível de risco	[BAIXO / MÉDIO / ALTO]
CrITÉRIOS do nível de risco	[Quais critérios da Res. CD/ANPD nº 2/2022 se aplicam]
Dados pessoais tratados	[CATEGORIAS – cadastrais, sensíveis, financeiros, etc.]

Volume de titulares afetados	[ESTIMATIVA]
Subcontratação autorizada?	[SIM/NÃO – se sim, listar sub-operadores]
Transferência internacional?	[SIM/NÃO – se sim, fundamento legal Art. 33 LGPD]
Due Diligence aplicada	[Score% – opcional, baseado em questionário]
Cadastrado em / por	[DATA – NOME do responsável]



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Operador: Empresa Hipotética Tecnologia LTDA · CNPJ 00.000.000/0001-00

Serviço: hospedagem em nuvem do sistema de Ouvidoria (SaaS) · Papel: OPERADOR · Contrato: 045/2024 · Vigência: 01/01/2024 a 31/12/2026

Cláusulas LGPD: SIM (incluídas na minuta) · Tipo: CONTRATO_NOVO_CLAUSULAS · Nível de risco: MÉDIO

Dados: cadastrais + conteúdo das manifestações da Ouvidoria · Volume: ~1.200 titulares/ano

Subcontratação: não · Transferência internacional: não (DC em SP)

Cadastrado em 15/01/2024 por Pedro Costa (Procuradoria)



Registro de Solicitação DSR (Direitos do Titular)

QUANDO USAR

Na Fase 6 do PGP, pra cada solicitação recebida pelo canal DSR. Mantém registro do prazo de resposta (15 dias úteis — Art. 19 II LGPD) e da resposta dada. Reproduzir 1 ficha por solicitação.

Formulário

Número da solicitação	[PROTOCOLO INTERNO]
Data de recebimento	[DATA]
Canal de entrada	[E-mail / Formulário web / Telefone / Presencial / Carta]
Nome do titular	[NOME DO TITULAR]
Contato do titular	[E-MAIL ou TELEFONE]
Identidade confirmada?	[SIM/NÃO/COM RESSALVAS – método de confirmação]
Tipo de solicitação (Art. 18 LGPD)	[CONFIRMAÇÃO / ACESSO / CORREÇÃO / ANONIMIZAÇÃO / BLOQUEIO / ELIMINAÇÃO / PORTABILIDADE / OPOSIÇÃO / INFORMAÇÃO SOBRE COMPARTILHAMENTO / REVOGAÇÃO DE CONSENTIMENTO]
Descrição da solicitação	[Texto literal do pedido OU resumo]
Setor envolvido (processo de origem)	[QUAL setor trata os dados solicitados]
Status atual	[ABERTA / EM ANÁLISE / RESPONDIDA /

	NEGADA]
Prazo de resposta (15 dias úteis)	[DATA LIMITE]
Data da resposta	[DATA]
Resposta dada	[Texto da resposta enviada ao titular]
Justificativa (se NEGADA)	[Fundamento legal pra negativa – Art. 18 §4º / outros]
Responsável pelo atendimento	[NOME – DPO ou pessoa designada]

Indicadores recomendados

- ▶ % de solicitações respondidas dentro do prazo (meta: 100%)
- ▶ Tempo médio de resposta (em dias úteis)
- ▶ Distribuição por tipo de solicitação (qual direito é mais exercido?)
- ▶ Distribuição por canal de entrada



EXEMPLO PREENCHIDO

Apenas referência — adapte à realidade da sua Instituição

Protocolo: DSR-2027-014 · Recebida em 10/04/2027 · Canal: e-mail
[\[email protected\]](#)

Titular: João Silva ([\[email protected\]](#)) · Identidade confirmada via cópia de RG (anexa)

Tipo: ACESSO · Solicita cópia das informações que a PMVegas tem sobre ele em manifestações de Ouvidoria do último ano

Setor envolvido: Ouvidoria · Status: RESPONDIDA · Prazo: 02/05/2027 ·
 Data resposta: 18/04/2027 (8 dias úteis)

Resposta: encaminhada cópia das 3 manifestações em nome do titular, com tarja em dados de terceiros mencionados

Responsável: Maria Silva (Encarregada)